

Personal Cybersecurity Guardian Agent

Future Roadmap: From Proof of Concept to Industry-Grade System

Anusha Prakash | Student ID: 002306070

INFO7375 - Prompt Engineering & AI | Northeastern University

April 2026

Purpose: *The semester deliverable proves the core thesis: a multi-agent system with live threat intelligence produces more accurate, calibrated security verdicts than a base LLM operating on training data alone. This roadmap describes the architectural decisions that separate a proof of concept from a production system, and explains why each one requires resources, time, or infrastructure beyond a single-semester scope.*

The roadmap is organized into three tiers. Tier 1 closes gaps in the current semester build. Tier 2 addresses production hardening. Tier 3 describes industry-scale expansion. Each item names the specific technology, the architectural gap it closes, and the tradeoff it involves.

Current State: Semester Deliverable

Component	What It Does	Known Limitation
CISA KEV Index (Pinecone)	1,566 actively exploited CVEs, snapshot from April 2026	Goes stale as new CVEs are added to KEV daily
NVD Index (Pinecone)	90,560 HIGH/CRITICAL CVEs from 1988 to 2022	Missing 2023 to 2025 NVD records; covered by KEV for actively exploited CVEs only
PhishTank Index (Pinecone)	57,705 verified phishing URLs, snapshot from April 2026	Static snapshot; new phishing campaigns not captured
VirusTotal API	Mocked in development; real API for final evaluation only	500 requests per day on free tier; not viable for real traffic
Synthesis Layer	Conflict resolution across two agents using five rules	No feedback loop; verdicts are not used to improve future performance
Contextual Intervention	GPT-4o mini prompt producing situation-specific action steps	Generic action steps; not personalized to user device or operating system
Evaluation	40-URL labeled test set with precision, recall, false positive rate	Small sample; does not represent full phishing distribution

Deployment	Streamlit on Hugging Face Spaces, free tier	No SLA; Pinecone index is static
------------	---	----------------------------------

Tier 1: Near-Term Enhancements

Tier 1 Closing Semester Build Gaps <i>Timeframe: Next semester, approximately 3 months</i>

1.1 Continuous KEV and PhishTank Sync

The current CISA KEV and PhishTank indexes are static snapshots. Every day that passes, new CVEs are added to KEV and new phishing URLs are verified by PhishTank. A production system cannot run on stale threat intelligence.

Architecture: A lightweight sync service runs on a daily cron schedule. For KEV, it fetches the full JSON feed and compares dateAdded fields against the last sync timestamp, upserting only new records into Pinecone. For PhishTank, it downloads the verified-online CSV and compares phish_id values. Only net-new records are embedded and upserted. The Pinecone upsert operation is additive; existing records are untouched.

Technology: Python APScheduler or a cloud-native cron such as AWS EventBridge or Google Cloud Scheduler. Redis to store the last sync timestamp. Estimated build time: 4 hours.

User impact: The interface displays a data freshness timestamp: 'Threat intelligence last updated: 2 hours ago.' Users know exactly how current their verdicts are.

Data Source	Update Frequency	Sync Method	Estimated New Records Per Day
CISA KEV	Multiple times per week	dateAdded field diff	2 to 5 new CVEs
PhishTank	Continuous	phish_id diff	200 to 500 new URLs
NVD	Daily	modStartDate parameter API	50 to 100 new or modified CVEs

1.2 Full NVD Coverage with Resume Logic

The current NVD index covers 1988 to 2022 only. The download timed out at record 190,000 of 344,184. The missing 154,000 records are 2023 to 2025 CVEs, covered partially by CISA KEV for actively exploited ones but not for the broader universe of HIGH and CRITICAL severity vulnerabilities.

Architecture: The NVD API 2.0 supports a modStartDate parameter that returns only records published or modified after a given date. Rather than re-downloading 344,000 records, a resume script starts from the last successfully downloaded record and fetches forward. A checkpoint file stores the last successful startIndex and timestamp, so any future timeout resumes from that exact point.

Technology: Enhanced index_pinecone.py with a --resume-from flag. Checkpoint stored in data/nvd/checkpoint.json. Estimated build time: 2 hours.

1.3 VirusTotal Production Integration with Intelligent Caching

The current system mocks VirusTotal responses during development. Real deployment requires the live API, but the free tier at 500 requests per day is not viable for even moderate traffic.

Architecture: A Redis cache layer sits between the application and the VirusTotal API. Every URL is hashed using SHA-256 before the API call. If the hash exists in Redis with a TTL under 24 hours, the cached result is returned with no API call consumed. Cache hit rate for a typical deployment is estimated at 40 to 60 percent, effectively doubling the usable API quota.

Upgrade path: The VirusTotal Academic Program provides 1,000 requests per day at no cost. For commercial deployment, the Standard tier at approximately \$2,880 per year provides 100,000 requests per day, sufficient for a B2C product.

Tier	Requests Per Day	Cost	Suitable For
Free (current)	500	\$0	Development and demo only
Academic Program	1,000	\$0 (application required)	Research and course projects
Standard	100,000	~\$2,880 per year	B2C product launch
Enterprise	Unlimited	Custom pricing	ISP and enterprise deployment

1.4 Phishing Agent Evaluation: End-to-End Verdict Testing

The current Recall@5 test measures Pinecone retrieval quality in isolation. The correct evaluation for the phishing agent measures final verdict accuracy using the full pipeline including VirusTotal.

Architecture: A labeled test set of 200 URLs: 100 known phishing from PhishTank verified post-2024, and 100 known safe from the Alexa Top 1000 domains. Each URL is run through the complete phishing agent: VirusTotal mock, Pinecone RAG, and GPT-4o mini synthesis. Verdict is compared against the ground truth label.

Metric	Definition	Target
Precision	Of URLs labeled MALICIOUS, what percentage actually are?	90% or above
Recall	Of actually malicious URLs, what percentage were caught?	85% or above
False Positive Rate	Of safe URLs, what percentage were incorrectly flagged?	5% or below
UNCERTAIN Rate	What percentage of verdicts reflect calibrated abstention?	Report only; no target

Tier 2: Production Hardening

Tier 2 From Demo to Deployable Product | *Timeframe: 6 to 12 months*

2.1 Zero-Day Phishing Detection via Domain Intelligence

The most dangerous phishing URLs are the ones VirusTotal has not yet seen: registered yesterday, not yet flagged by any engine. The current system returns INSUFFICIENT_EVIDENCE for these cases. Production must do better.

Architecture: A domain intelligence layer runs in parallel with VirusTotal. For any submitted URL, a WHOIS lookup retrieves the domain registration date. A domain registered within the last seven days, combined with a suspicious TLD (.xyz, .tk, .ml, .cf) and no established reputation, automatically escalates the verdict to UNCERTAIN regardless of VirusTotal engine count. This catches zero-day phishing campaigns before they enter any threat database.

Technology: The python-whois library for domain age lookup, with RDAP protocol as fallback for newer TLDs. Estimated build time: 6 hours.

Tradeoff: WHOIS lookups add 1 to 3 seconds of latency per query. This is acceptable for a security tool where users expect deliberate analysis, but not acceptable for a real-time browser extension.

Architectural significance: *This addresses the scenario where VirusTotal clears a URL (zero flags) but Pinecone finds suspicious patterns and the domain was registered two days ago. Current system verdict: UNCERTAIN. Future system verdict: LIKELY_MALICIOUS with domain age evidence cited explicitly. This is the difference between a cautious system and an intelligent one.*

2.2 URL Unshortening and Redirect Resolution

Sophisticated phishing increasingly uses URL shorteners, redirect chains, and JavaScript-based redirects to hide the final malicious destination. The current system analyzes the submitted URL, not where it actually leads.

Architecture: Before any VirusTotal or Pinecone call, a URL resolution layer follows all redirects to the final destination. It maintains a redirect chain log that becomes part of the evidence output. If any URL in the chain has been previously flagged, the verdict escalates regardless of the final URL's reputation.

Technology: Python requests with `allow_redirects=True` and a custom User-Agent. Playwright for JavaScript-rendered redirects. Timeout set at 5 seconds per hop, maximum 10 hops. Estimated build time: 8 hours.

Edge case: Some legitimate URLs also use redirects for marketing UTM parameters and CDN routing. The system must distinguish between tracking redirects (safe) and destination-hiding redirects (suspicious) using the domain reputation of each hop.

2.3 Adversarial Robustness: Evasion Technique Handling

Security tools are adversarial targets. Phishing operators actively test their URLs against VirusTotal and PhishTank before launching campaigns. A production system must handle known evasion techniques.

Evasion Technique	How It Works	Mitigation
Homograph attacks	Uses lookalike Unicode characters, such as paypal.com with a capital I instead of lowercase l	Unicode normalization and visual similarity detection
Subdomain abuse	Uses a legitimate-looking subdomain in front of a malicious domain, such as legitimate-looking.paypal.malicious.com	Parse domain and subdomain separately; flag brand names appearing in the subdomain position
HTTPS as trust signal	Phishing sites increasingly use HTTPS to appear legitimate	HTTPS score removed from credibility calculation; certificate age checked instead
Cloaking	Shows safe content to scanners, malicious content to real users	Multiple User-Agent testing and mobile versus desktop comparison
Time-delayed activation	URL is safe for first 24 hours, then redirects to malicious content	Cache invalidation policy: re-check flagged URLs after 24 hours

2.4 Cross-Session Memory with Explicit User Consent

The current system is fully stateless. Every session starts fresh with no knowledge of prior interactions. For a user who regularly checks suspicious URLs, this means re-establishing context every session.

Architecture: An opt-in personal threat history stored in PostgreSQL. Each record contains a URL hash (not the URL itself), verdict, confidence score, timestamp, and a user-controlled expiry defaulting to 30 days. When a user submits a URL, the system checks the hash against their history. If the verdict has changed (previously SAFE, now MALICIOUS), the user is explicitly alerted.

Privacy design: URL hashes are one-way; the original URL cannot be reconstructed. No personally identifiable information is stored. Opt-in only; the default is stateless. The user can delete their history at any time. Compliant with GDPR Article 17 (right to erasure) by design.

2.5 OS-Aware Contextual Intervention

The current contextual intervention layer produces generic action steps. The instruction 'Update your software' means something different on Windows, macOS, Linux, iOS, and Android. A production system would detect the user's operating system and produce device-specific instructions.

Architecture: Browser User-Agent parsing detects OS at session start. The intervention prompt includes the OS as a context variable. GPT-4o mini generates OS-specific update instructions with exact menu paths, keyboard shortcuts, and platform-specific steps.

Example: VULNERABLE verdict on Zoom 5.15.2. Current output: 'Update Zoom immediately.' Future output on macOS: 'Open Zoom. Click the Zoom menu in the top-left corner. Select Check for Updates. Follow the installer. This takes approximately 2 minutes and requires no restart.'

Tier 3: Industry-Scale Expansion

Tier 3 Enterprise and Industry-Grade Capabilities | Timeframe: 12 to 24 months

3.1 Federated Threat Intelligence

The current system uses three data sources: VirusTotal, CISA KEV, and PhishTank. Security operations centers use dozens. A production system at industry scale would integrate the full threat intelligence ecosystem.

Source	What It Adds	Integration Complexity
MISP (Malware Information Sharing Platform)	Community-shared indicators of compromise: IP addresses, file hashes, domains	Medium; MISP REST API, open source self-hostable
AlienVault OTX	Open threat exchange with 19M+ indicators from 100,000+ contributors	Low; free public API

Shodan	Internet-connected device intelligence; identifies exposed services on IP addresses	Low; free tier API available
Microsoft MSRC	Microsoft Security Response Center; official patch database for all Microsoft products	Medium; structured JSON feed
Apple Security Updates	Official CVE-to-patch mapping for iOS, macOS, and Safari	High; no structured API, requires HTML parsing
CIRCL MISP Taxonomies	Standardized classification of threat actors, campaigns, and malware families	Low; open source taxonomy library

Architecture: Each threat intelligence source becomes a tool available to the vulnerability or phishing agent. LangGraph's tool-calling architecture makes this extensible: adding a new source means adding a new tool node, not redesigning the pipeline.

3.2 Browser Extension: Real-Time Protection

The current system requires the user to actively submit a URL or software version. A browser extension would provide passive real-time protection, checking every link the user hovers over before they click it.

Architecture: A Chrome or Firefox extension captures link hover events and sends the URL to the Guardian Agent backend via a lightweight WebSocket connection. The verdict is displayed as a tooltip before the user clicks. For MALICIOUS verdicts, a blocking overlay appears. The extension uses the same backend API as the Streamlit interface; no duplicate logic is required.

Technical challenge: Latency. The current pipeline takes 3 to 8 seconds for a full analysis. A hover tooltip must respond in under 500 milliseconds. This requires a fast-path architecture: domain reputation cache checked first (under 50ms), VirusTotal async call initiated in background, result surfaced when available.

Privacy consideration: The extension must not send every URL the user visits to the backend. Only URLs the user explicitly hovers over for more than one second are submitted. This prevents passive surveillance of browsing history.

3.3 Human-in-the-Loop Feedback and Continuous Improvement

The current system produces verdicts but learns nothing from them. Every verdict is a one-way output. A production system would close the loop, using user feedback to continuously improve the model.

Architecture: Every verdict in the Streamlit interface includes a thumbs up or thumbs down button. Thumbs down opens a structured feedback form: Was this verdict wrong? If so, what was the correct verdict? This feedback is stored anonymously with user consent and periodically used to generate fine-tuning examples. The RLHF loop: user feedback, then curated fine-tuning dataset, then quarterly model update, then improved verdicts.

Research alignment: This is Reinforcement Learning from Human Feedback applied to a security domain-specific model. It is the same mechanism used to align GPT-4 to human preferences, applied here to align the system's plain-English explanations to what non-technical users actually find clear and actionable.

3.4 Multi-Language Support

The current system produces English-only output. Phishing attacks are global. The PhishTank dataset demonstrates this directly: Allegro, a Polish marketplace, is the second most-targeted brand in the current index with 1,323 verified phishing URLs. A Polish user checking an Allegro phishing email currently receives an English verdict.

Architecture: Language detection runs on the user's input text before any agent dispatch. If the input is Polish, French, Portuguese, or any of GPT-4o mini's supported languages, the synthesis prompt and intervention layer produce output in the detected language. No additional model is required; GPT-4o mini handles multilingual output natively.

Market opportunity: The top targeted brands in PhishTank reveal geographic distribution: Allegro (Poland), Bradesco (Brazil), Optus (Australia). These markets are underserved by English-only security tools. Multi-language support is not a feature; it is access equity.

3.5 Whole-Codebase Vulnerability Assessment

The current system checks a single software version at a time. A more powerful capability, relevant for developers and IT administrators, would assess an entire codebase or dependency manifest for known vulnerabilities.

Architecture: The system accepts a package.json, requirements.txt, pom.xml, or any dependency manifest as input. It parses all dependencies and versions, then runs the vulnerability agent in parallel across all entries using LangGraph's parallel node execution. The synthesis layer produces an aggregate risk score with a prioritized list: critical items first, with remediation paths and estimated effort.

Industry relevance: This directly overlaps with commercial offerings from Snyk, Dependabot, and Socket.dev. The differentiation is the plain-English explanation layer and the non-technical user framing; most existing tools produce output readable only by developers.

3.6 Agentic Email Monitoring with Explicit Consent

The current system requires the user to copy and paste suspicious email text. A future version, with explicit and revocable user consent, would monitor the user's inbox and proactively flag suspicious emails before the user even opens them.

Architecture: Gmail or Outlook OAuth integration. For each new email, a lightweight pre-screening agent extracts links and checks sender domain reputation. Only emails flagged by pre-screening are run through the full phishing agent. The user receives a push notification: 'A suspicious email arrived. We have analyzed it. Here is what we found.'

Privacy design: Email content is processed in memory and never stored. The OAuth token is scoped to read-only access. The user can revoke at any time. A full audit log records what was accessed and when.

Ethical boundary: *This capability sits at the boundary of helpful and invasive. The difference between a security tool and surveillance is consent, transparency, and revocability. The architecture above treats all three as first-class constraints, not afterthoughts. If those constraints cannot be met in a given deployment context, this feature should not be built.*

Evaluation at Scale: What Industry-Grade Testing Looks Like

The semester deliverable uses 40 labeled URLs and 20 conflict scenarios. Production requires a fundamentally different evaluation infrastructure.

Evaluation Type	Semester Scope	Production Requirement
Phishing detection accuracy	40 URLs, manual labels	10,000+ URLs; continuous automated evaluation against PhishTank ground truth
CVE retrieval precision	20 queries, Recall@5	Full NVD held-out set; precision and recall by CVSS severity band
False positive rate	20 known-safe URLs	Alexa Top 10K domains; weekly automated regression
Latency	Not formally measured	P50/P95/P99 targets: under 3s / under 6s / under 10s
Calibration	Not measured	Expected Calibration Error: does 70% confidence correspond to 70% empirical accuracy?
Adversarial robustness	Not tested	Red team exercises covering homograph attacks, cloaking, time-delayed activation
Multi-language accuracy	Not applicable	Per-language precision and recall on translated phishing datasets

Closing

The semester deliverable proves a thesis. This roadmap describes a product. The distance between them is not a failure of the semester project; it is an honest accounting of what separates research from deployment.

Every item in this roadmap was identified because of something discovered during the semester build. The zero-day detection gap emerged from understanding why VirusTotal can miss new campaigns. The URL unshortening requirement emerged from thinking about how sophisticated phishing actually works. The OS-aware intervention emerged from recognizing that 'update your software' means nothing to someone who does not know where their update settings are.

The value of a proof of concept is not that it works. The value is that it reveals what production actually requires, and whether the thesis holds under those requirements. This system's thesis holds. The multi-agent architecture with live threat intelligence produces verdicts that a base LLM cannot replicate. This roadmap describes what it would take to deliver that capability to the people who need it most.